Architecture réseau: Défense de périmètre

GEF330 – Hiver 2021
CRI11

Mariam El Mezouar
Collège Militaire Royal du Canada
Génie électrique et génie informatique
Mariam.el-mezouar@rmc.ca
elmezouar.segfaults.net

Références

1. Oppenheimer, Priscilla, “Top-down Network Design”, Cisco Press, 2004.
2. NetFilter/iptables by Daniel Miessler, http://www.danielmiessler.com/study/iptables/

Aperçu

- Défense de périmètre
- Les Pare-feu sont d'abord des filtres
- Détection et prévention des intrusions
- Sécurité vs accessibilité
- Filtrage de paquets avec IPTables
- Exemples de pare-feu

Défense de périmètre

- La défense traditionnelle des réseaux considérait les réseaux comme des forteresses entourées de murs puissants qui empêcheraient les méchants de pénétrer. C’est la défense de périmètre.
- La défense en profondeur étend ce concept pour dire que notre réseau devrait avoir plusieurs couches de défenses.
  - Pare-feu
  - Détection d'intrusion
  - Authentification et gestion de compte
  - Limitations d'accès utilisateur
  - Journalisation et audit

Pare-feu.

- Un pare-feu (Firewall) est d'abord un filtre
- On peut l'implémenter comme un programme logiciel ou comme un dispositif matériel
- Il est utilisé pour interdire le passage d'information non autorisée, tout en permettant à l'information permise de passer
- Il prend des décisions vis-à-vis le passage/filtrage du trafic selon un ensemble des règles
    - C'est-à-dire d'autoriser le passage (PASS), le refuser (DROP) ou envoyer un RST/ACK (REJECT)

Pare-feu Statique vs Dynamique

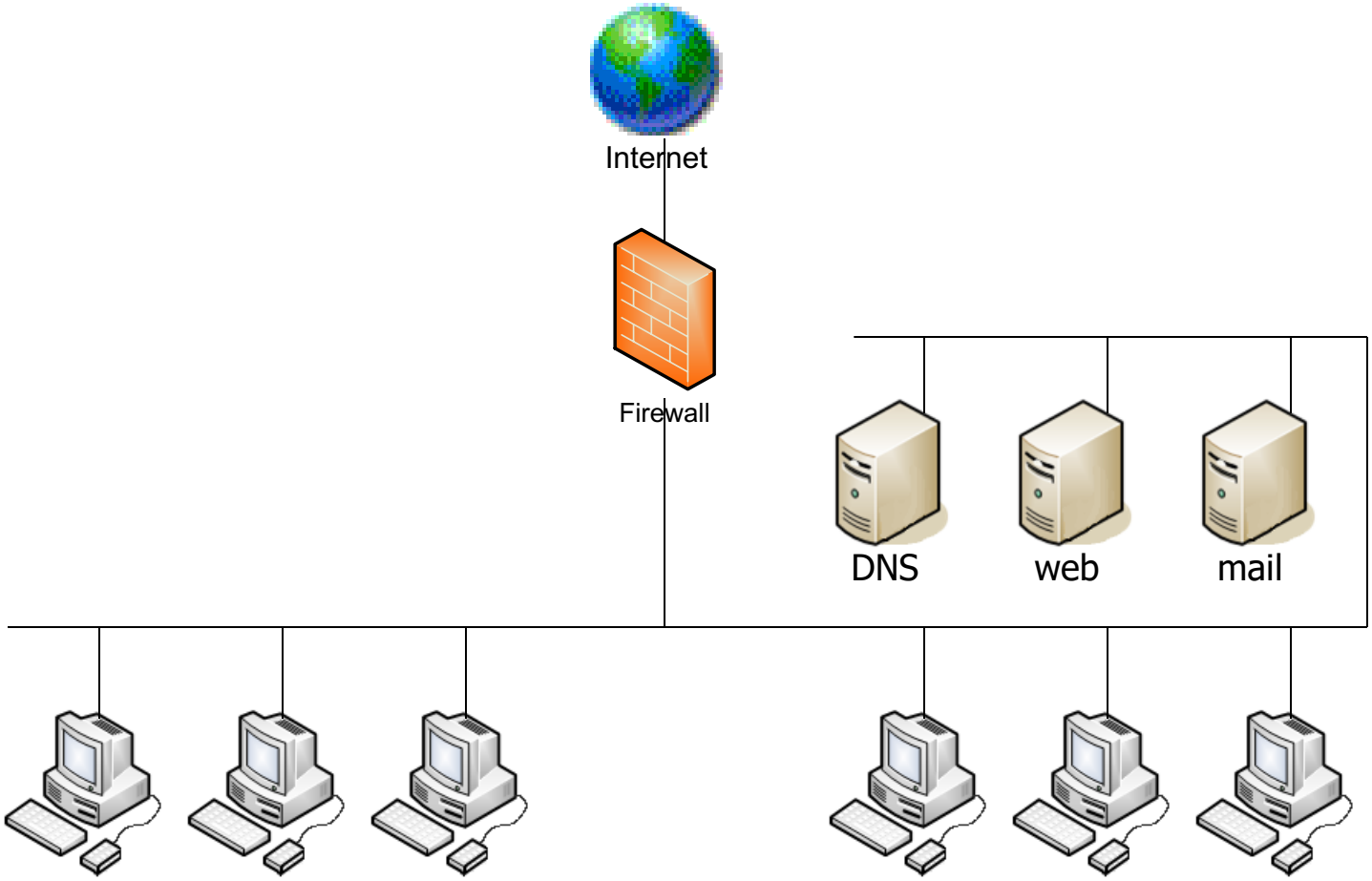
- Pare-feu statique : ne suit pas les connexions. Aucune connaissance de quelle adresse IP parle à qui.
- Pare-feu dynamique: peut identifier et suivre lorsqu'une connexion est établie. Les paquets faisant partie de cette connexion peuvent être traités différemment.
  - États possibles (iptables):
    - New: premier paquet en conversation. (c.-à-d. paquet SYN de prise de contact à trois voies TCP)
    - Established : paquets vus dans les deux sens. (c.-à-d. session TCP)
    - Related : une nouvelle connexion générée par une connexion établie. (c.-à-d. connexion de transfert de données FTP générée à partir d'une connexion de commande FTP)
    - Invalid: ne fait partie d'aucune connexion reconnue

- Pourquoi c’est important?

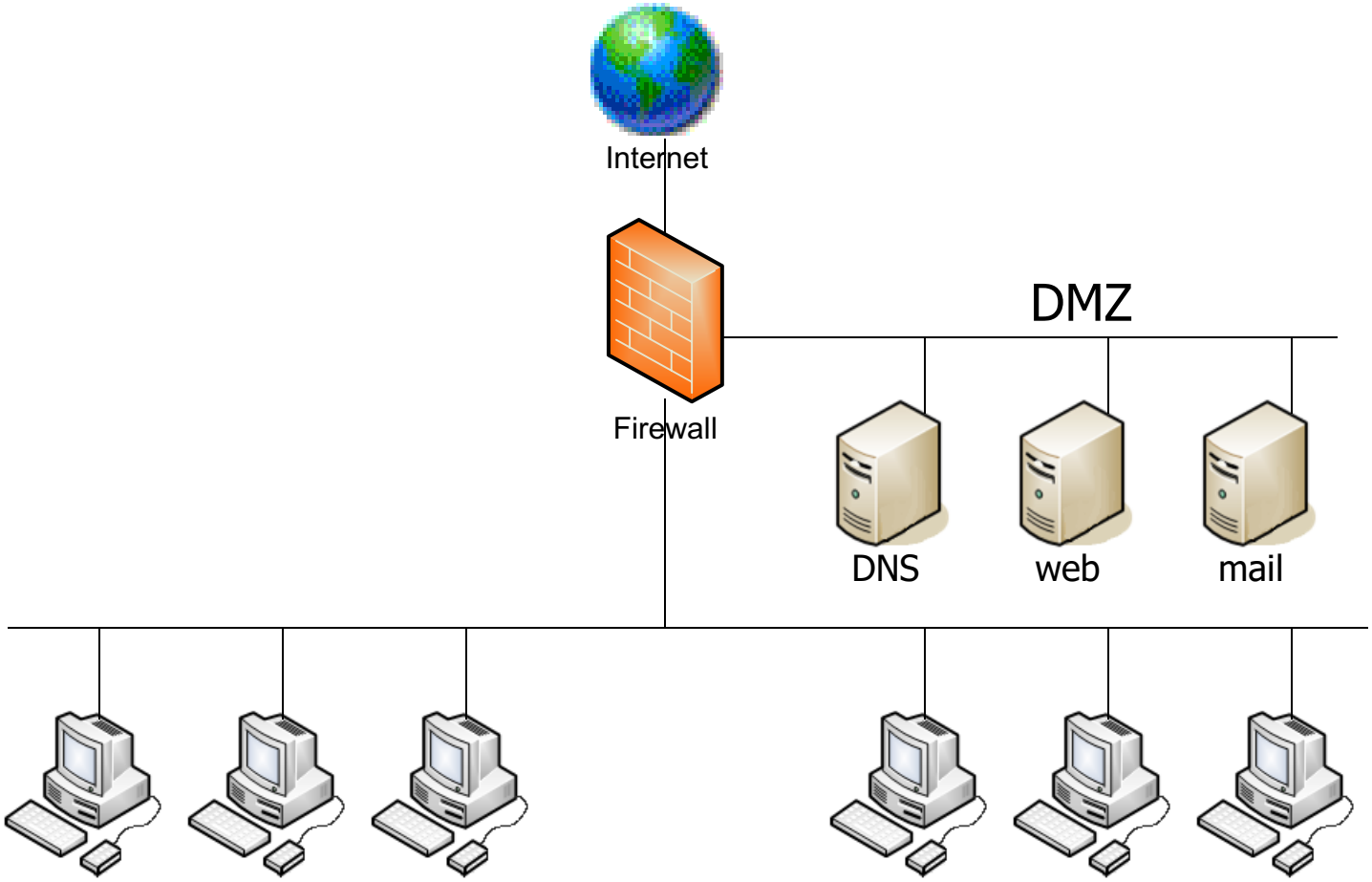
Pare-feu et architecture réseau

- Le placement du pare-feu est un problème non trivial.
  - Un petit réseau simple peut avoir un seul pare-feu entre lui et le monde extérieur.
  - Les réseaux plus grands et plus complexes peuvent être subdivisés en utilisant un ou plusieurs pare-feu.
- Le placement et la configuration du pare-feu est un composant majeur de la conception du réseau.
  - Celui qui obtiendra le poste Firewall & Architecture pour CyberX sera très, très occupé…

Architecture: Pare-feu 2-interfaces



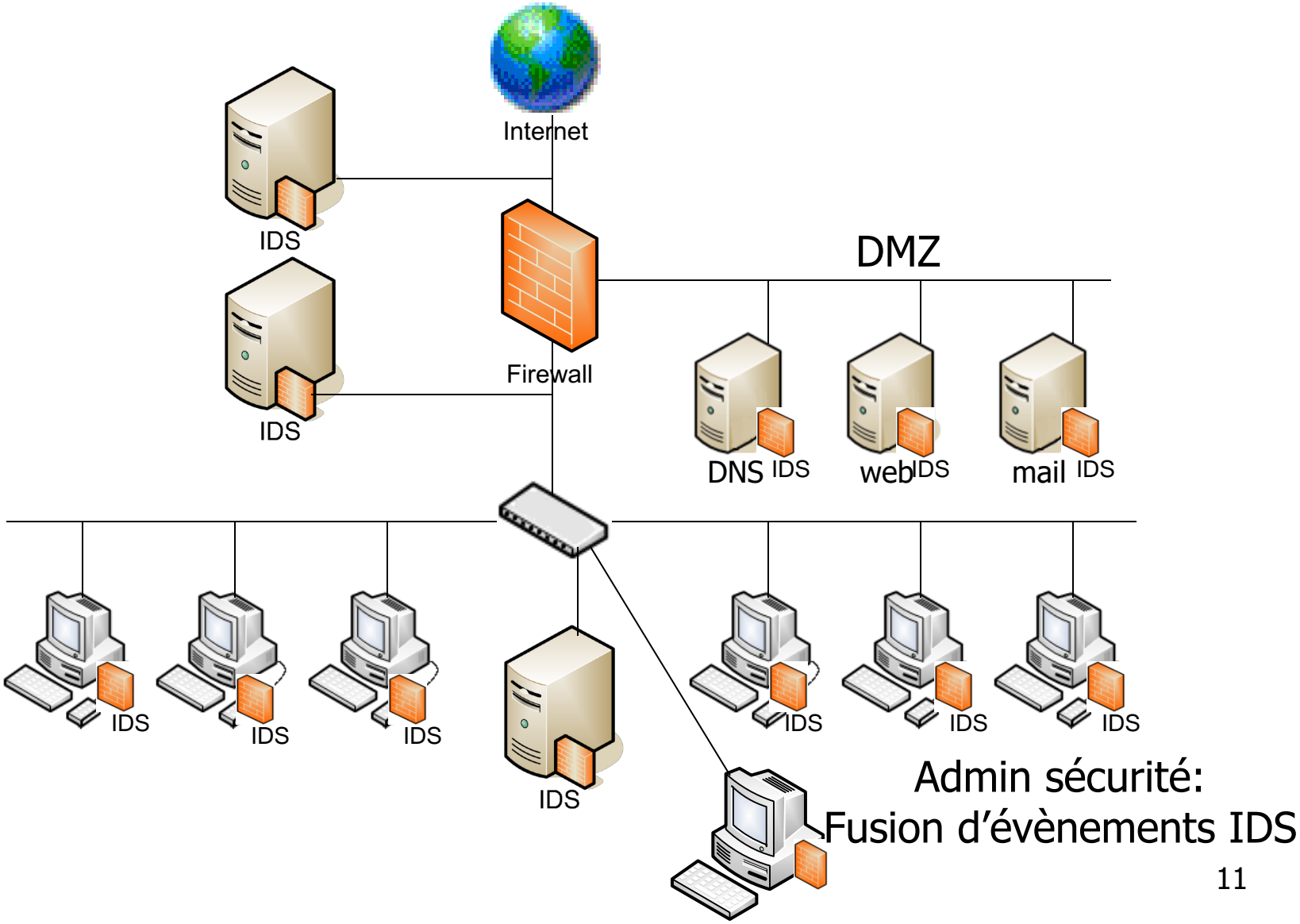
Architecture: Pare-Feu à 3-interfaces



Système de détection d'intrusion

- Un système de détection d'intrusion réseau (*Network Intrusion Detection System* - NIDS) est un moniteur
  - On peut l'implémenter comme un programme logiciel ou comme un dispositif matériel
  - Le moniteur surveille le réseau ou les activités d'un système pour trouver des activités malicieuses or des violations de politiques
  - Génère des alertes ou des rapports à un administrateur
  - Peut être basé sur des signatures ou sur des déviations par rapport à un trafic normal (appris).
- Prends des décisions vis-à-vis les alertes/rapport de trafic selon un ensemble de règles
  - C'est-à-dire « alerter » ou « ne pas alerter »
- Le trafic monitoré vient généralement d'un outil d'écoute réseau.

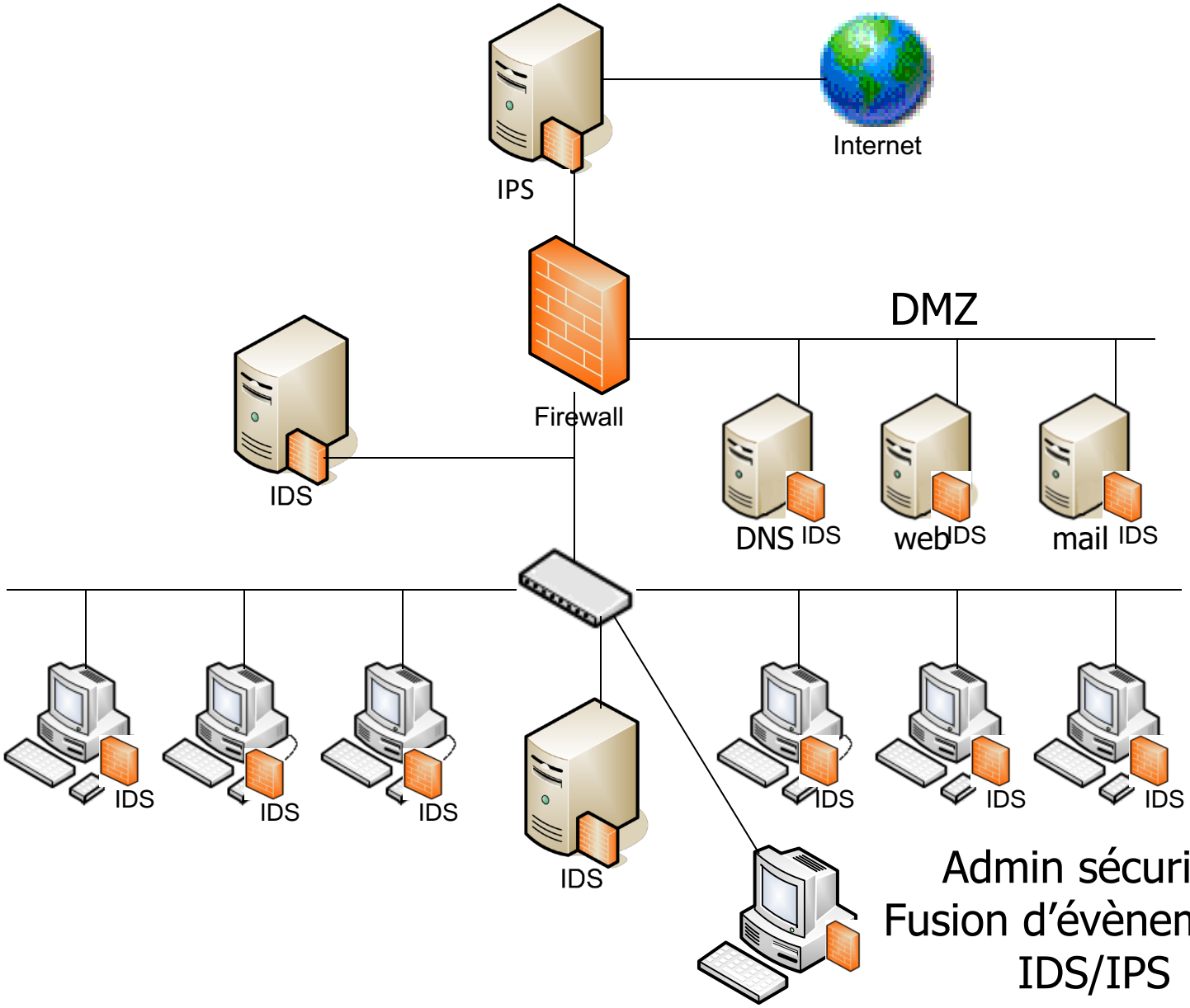
Architecture: placement d'IDS



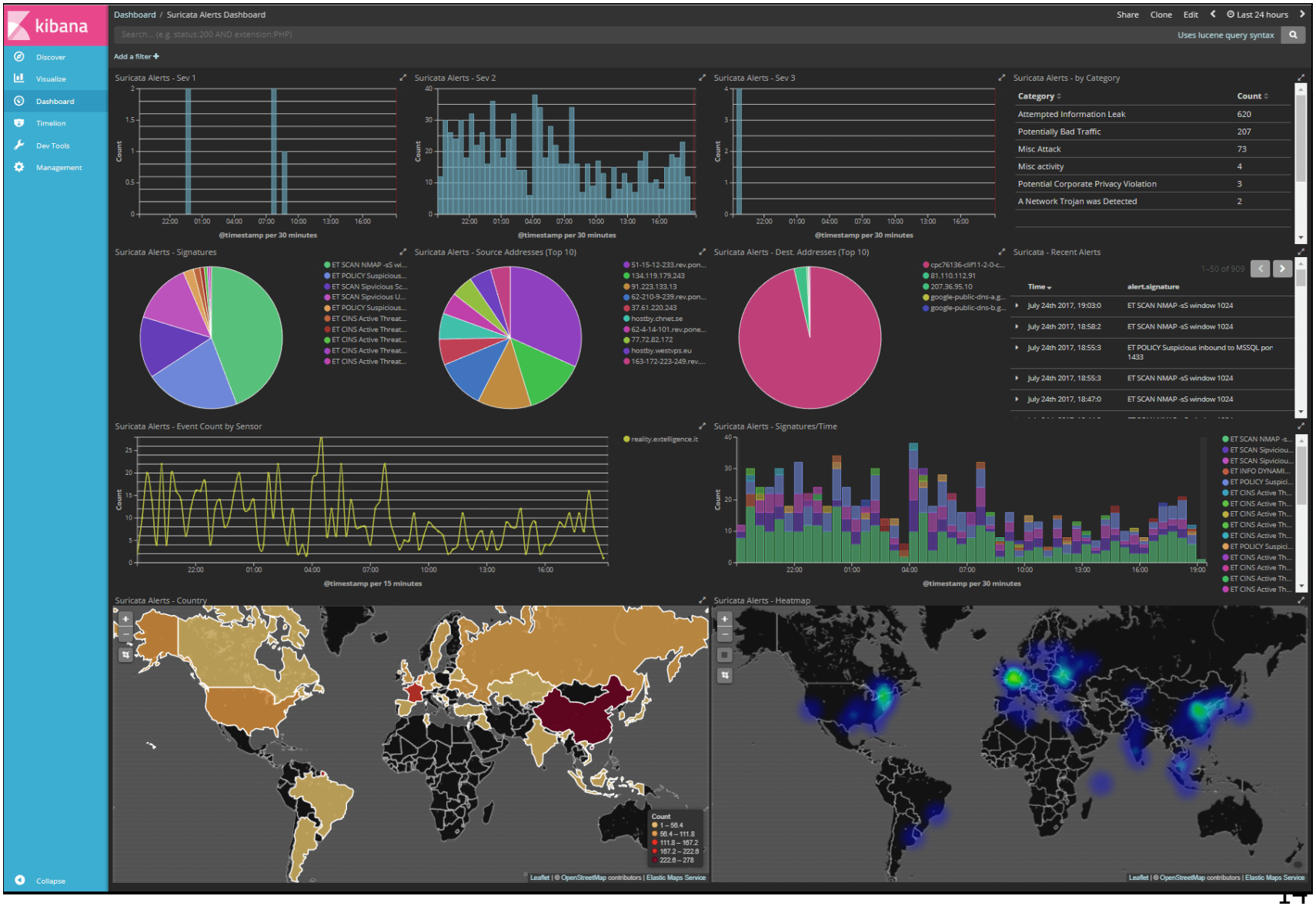
Intrusion Prevention System (IPS)

- Identique à un IDS, mais avec la possibilité de bloquer les paquets.
- La décision de supprimer le trafic est indépendante de la décision de produire des alertes sur le trafic.
  - Alert uniquement,
  - Drop seulement,
  - Drop & Alert, et
  - Pass.
- Nécessite une architecture réseau spécifique.
  - L'IPS doit être en ligne avec le flux de trafic réel.

Architecture: IPS Placement



IDS Monitoring



Securité vs Accessibilité

- Souvent, le principal instinct de la sécurité du réseau est:
  - ALERTE ROUGE!!! BLOQUEZ TOUT!
  - Contrôles et politiques strictes:
    - Applications en liste blanche uniquement.
    - Sites Web pré-approuvés uniquement.
    - Désactivez tous les scripts.
    - Désactivez tous les droits d'utilisateur.
    - Si possible, débranchez les câbles réseau du mur.
- N'oubliez pas que le but d'un réseau informatique est de permettre le partage des ressources et des informations.
  - Le réseau existe pour faciliter le travail effectué par une organisation.
  - Le verrouillage des choses dégrade la capacité de votre organisation à faire ce travail.

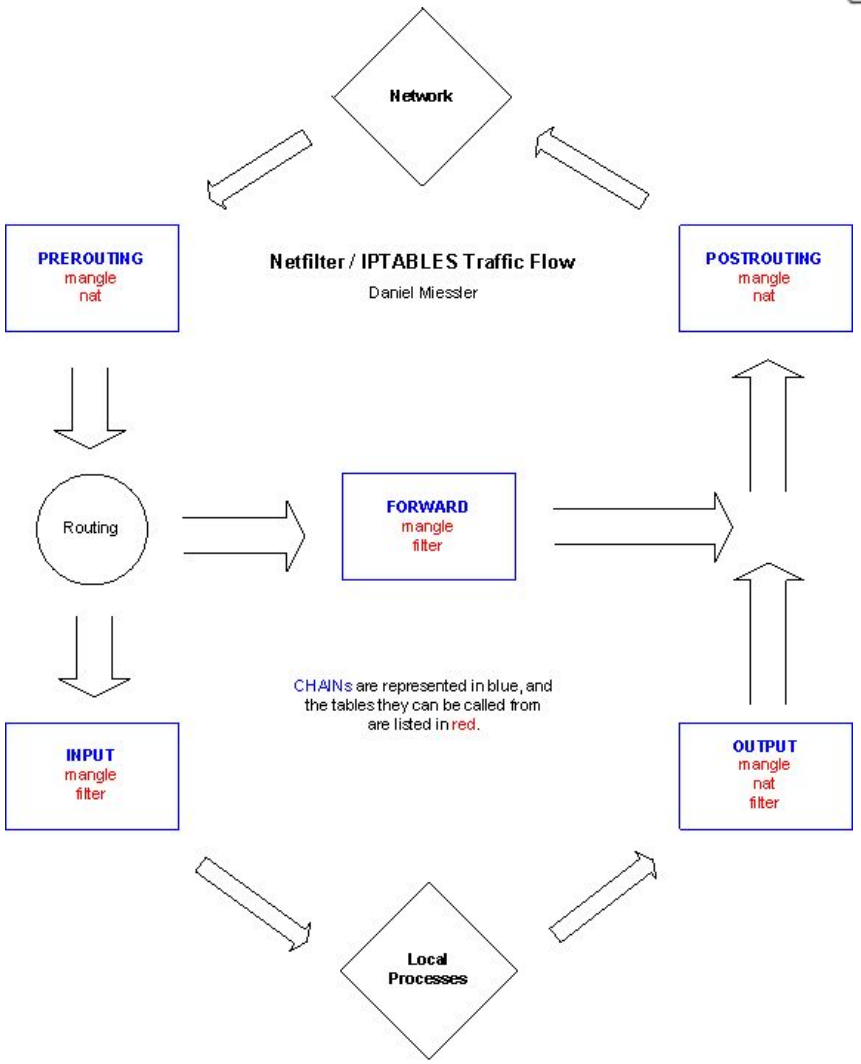
Sécurité vs Accessibilité

Quel est le bon niveau ??

Filtrage de paquets avec iptables

iptables (aka Netfilter) a trois éléments principaux:

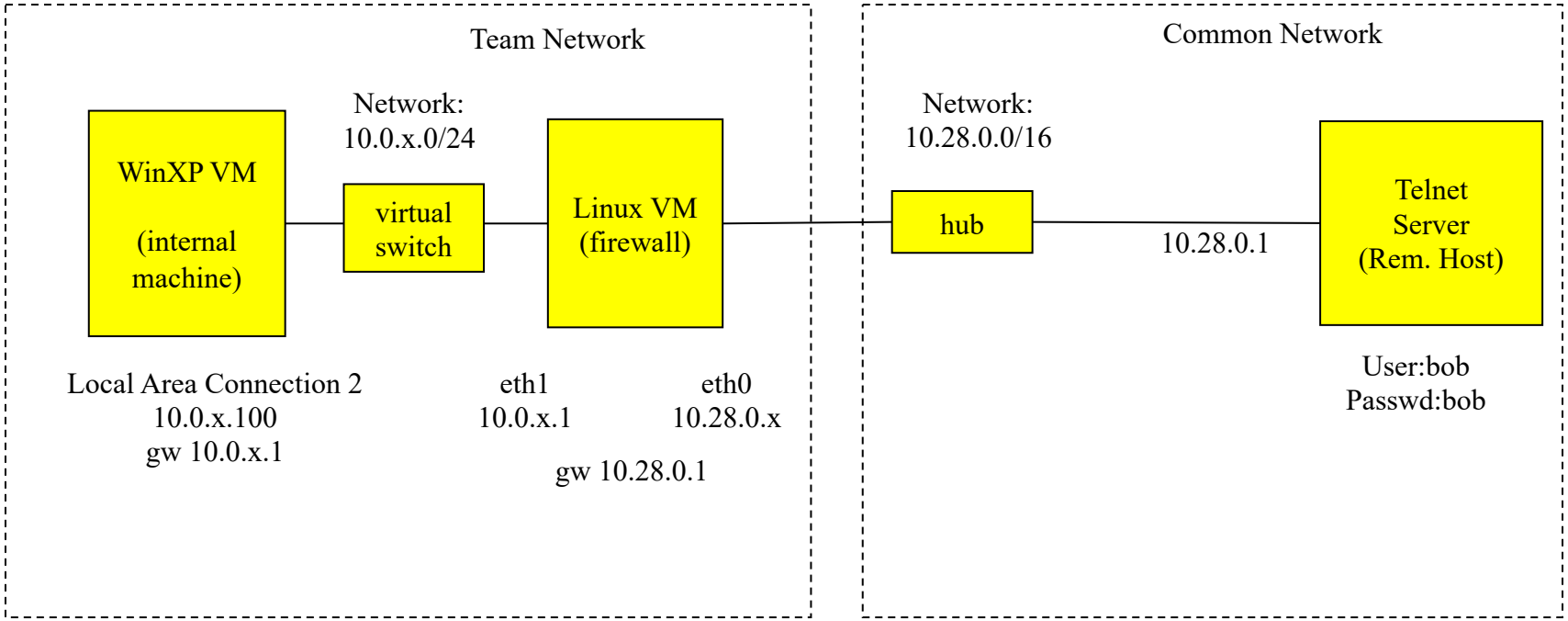
- Tables
  - Pièces principales de traitement de paquet
- Chaînes (*chains*)
  - Listes de règles associées aux tables
- Cibles (*targets*)
  - Résultat du déclenchement d'une règle dans une chaîne



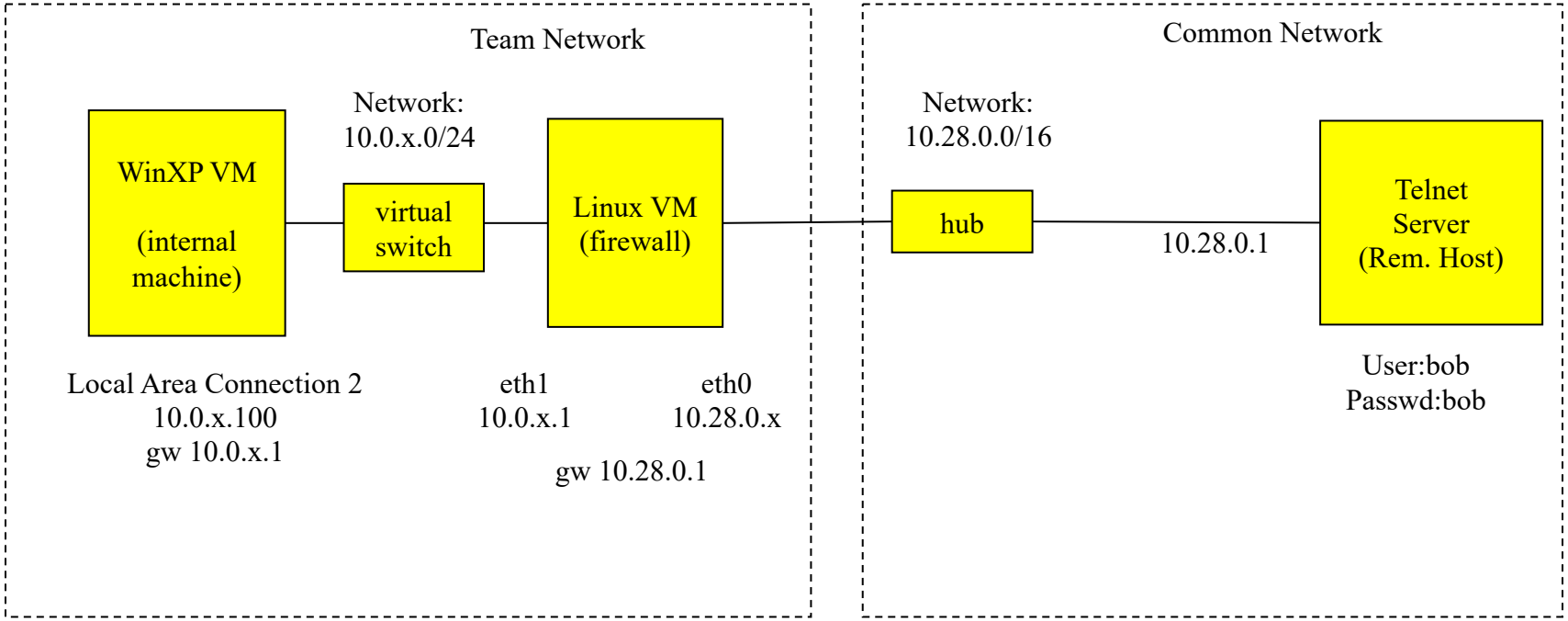
Filtrage de paquets avec IPTables

- Les règles de stratégie définissent les actions par défaut.
- La plupart des autres règles viennent par paires:
  - Une règle pour le trafic entrant,
  - Une règle pour le trafic sortant.
- Peut être très générique ou très spécifique.
  - L'ordre est important! Une fois qu'une règle est déclenchée, la chaîne se termine!
  - Vos règles générales peuvent empêcher le déclenchement de vos règles spécifiques.
- Sauvegardez, sauvegardez, sauvegardez.
  - Ne vous contentez pas de taper vos règles, sauf si vous expérimentez.
  - Les scripts sont la voie à suivre.

Exemple: Pare-Feu à 2-interfaces

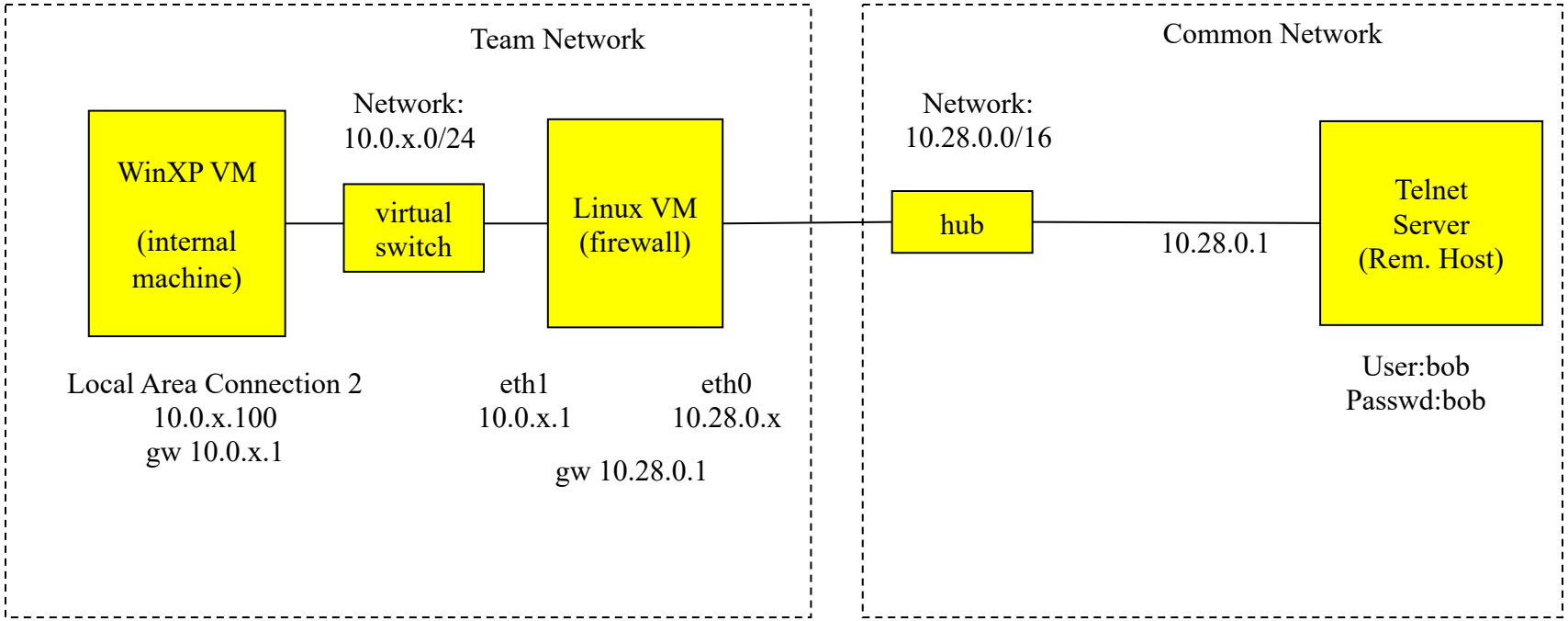


Exemple: Pare-Feu à 2-interfaces



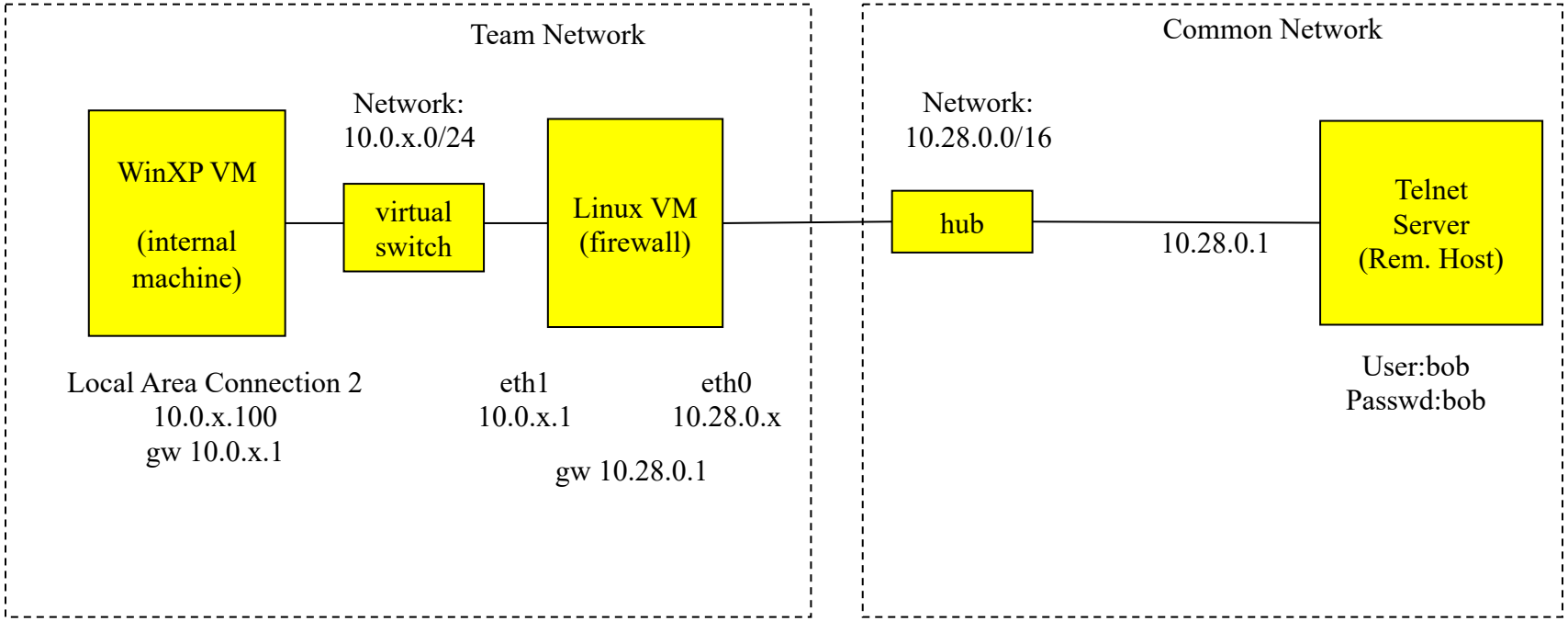

```
iptables --flush
iptables --policy INPUT DROP
iptables --policy FORWARD DROP
iptables --policy OUTPUT DROP
```

Exemple: Pare-Feu à 2-interfaces



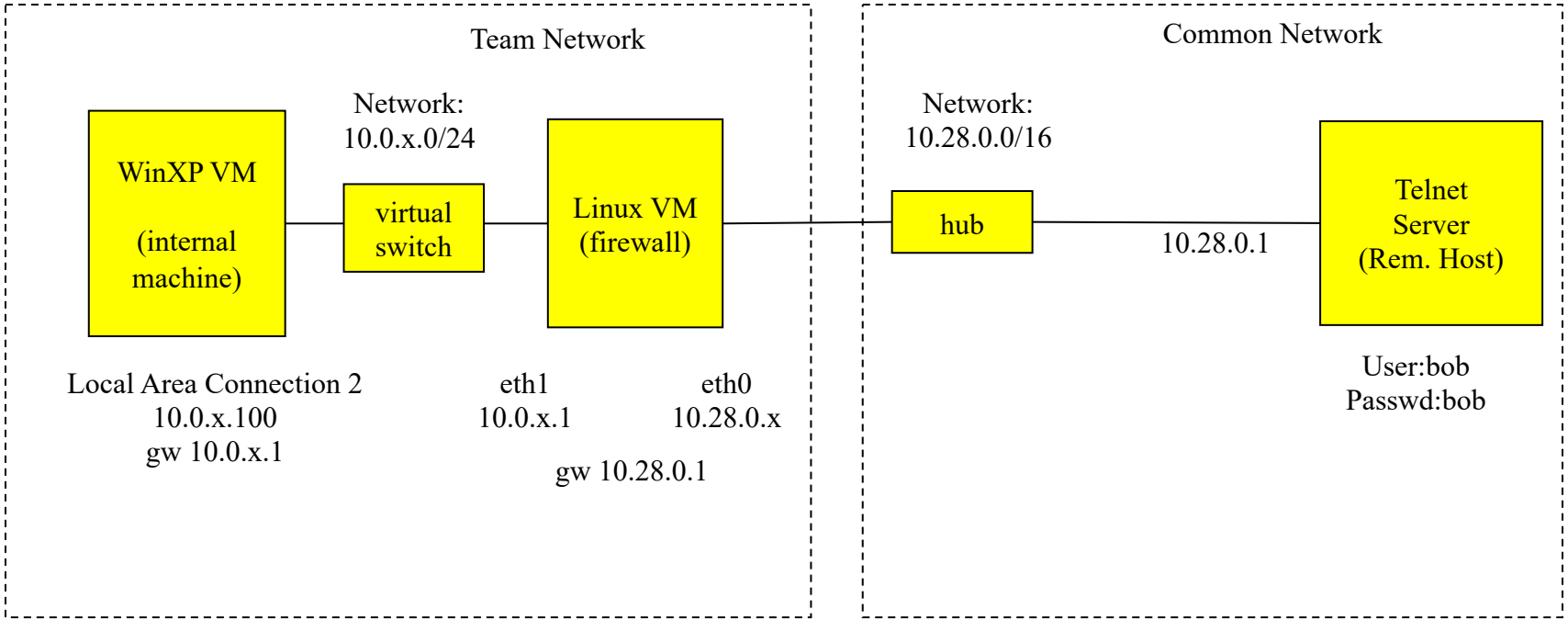
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

Exemple: Pare-Feu à 2-interfaces



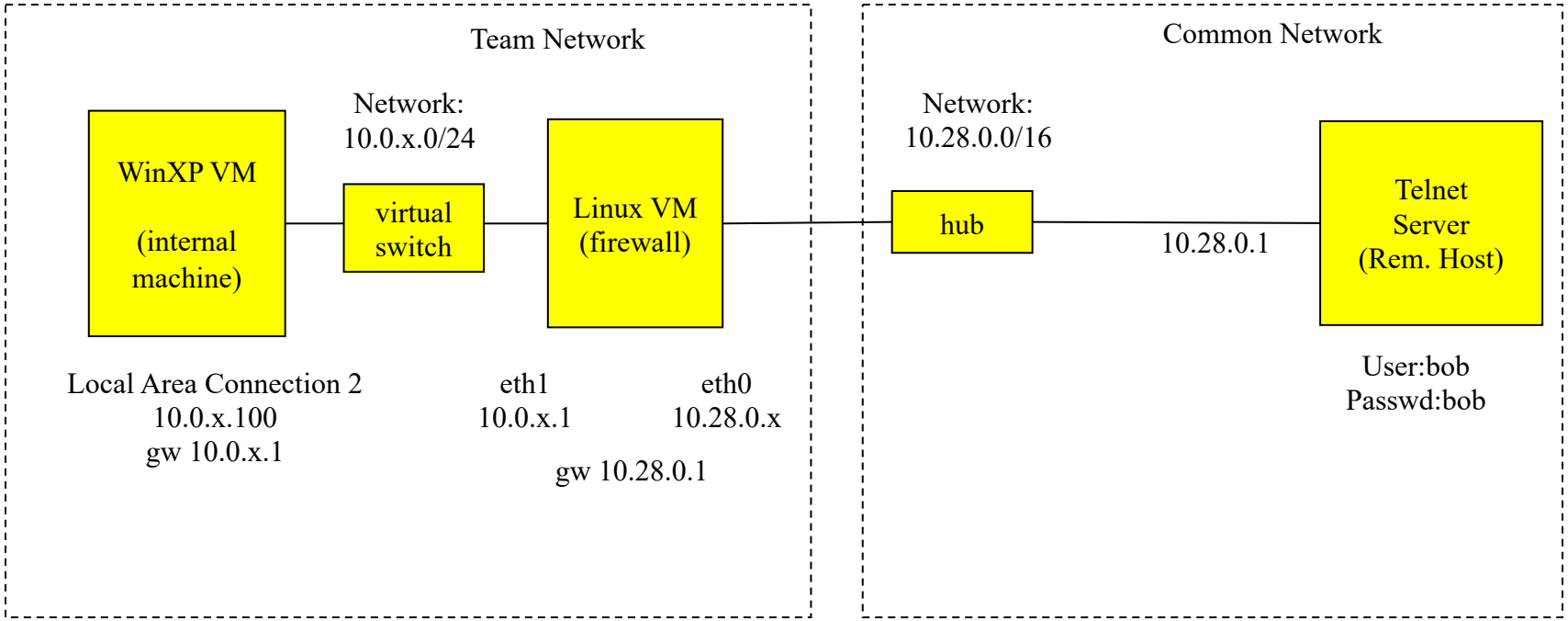
iptables -A FORWARD -s 10.0.x.0/24 -p icmp --icmp-type echo-request -j ACCEPT
iptables -A FORWARD -d 10.0.x.0/24 -p icmp --icmp-type echo-reply -j ACCEPT

Exemple: Pare-Feu à 2-interfaces




```
iptables -A FORWARD -s 10.0.x.0/24 -p tcp --dport 23 -j ACCEPT
iptables -A FORWARD -d 10.0.x.0/24 -p tcp --sport 23 -j ACCEPT
```

Exemple: Pare-Feu à 2-interfaces



iptables -A FORWARD -s 10.0.x.0/24 -p tcp --dport 23 -m state --state NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD -d 10.0.x.0/24 -p tcp --sport 23 -m state --state ESTABLISHED -j ACCEPT

Prochaine séance:

ARCHITECTURE RÉSEAU: TRADUCTION D'ADRESSES DE RÉSEAU